

Security Now! #1096 - 09-08-26

AI-Driven Expertise Loss

This week on Security Now!

- We start out with a classic old school hack against Dropbox.
- Next Patch Tuesday will be enabling "Memory Integrity" for many.
- Firefox moved to 155 and obtained a dumb Smart Window.
- CISA is terminating 6 most valuable cybersecurity services.
- OpenAI advanced to top of the heap with GPT-6 Astra.
- But... is it now hiding some of its thinking from monitoring?
- Nvidia is acquiring Hugging Face. Who's that good for?
- Google releases Gemini 3.8 Flash and Cyber. Is it good?
- Chinese cyberespionage is using AI to become more slippery.
- Matthew Green proposes a fascinating take on AI bug drought.
- A lifelong safety engineer contemplates AI-driven loss of expertise.

WHY ASIMOV PUT THE THREE LAWS OF ROBOTICS IN THE ORDER HE DID:

POSSIBLE ORDERING

CONSEQUENCES

1. (1) DON'T HARM HUMANS
2. (2) OBEY ORDERS
3. (3) PROTECT YOURSELF

[SEE ASIMOV'S STORIES]

BALANCED
WORLD

1. (1) DON'T HARM HUMANS
2. (3) PROTECT YOURSELF
3. (2) OBEY ORDERS

EXPLORE MARS!  HAHA, NO. IT'S COLD AND I'D DIE.

FRUSTRATING
WORLD

1. (2) OBEY ORDERS
2. (1) DON'T HARM HUMANS
3. (3) PROTECT YOURSELF



KILLBOT
HELSCAPE

1. (2) OBEY ORDERS
2. (3) PROTECT YOURSELF
3. (1) DON'T HARM HUMANS



KILLBOT
HELSCAPE

1. (3) PROTECT YOURSELF
2. (1) DON'T HARM HUMANS
3. (2) OBEY ORDERS

 I'LL MAKE CARS FOR YOU, BUT TRY TO UNPLUG ME AND I'LL VAPORIZE YOU.

TERRIFYING
STANDOFF

1. (3) PROTECT YOURSELF
2. (2) OBEY ORDERS
3. (1) DON'T HARM HUMANS



KILLBOT
HELSCAPE

<https://xkcd.com/1613/>

Security News

Some things never change

In the midst of all the AI cybersecurity related news, I wanted to start out this week's podcast with a blast from the past. This bit of news brought a smile to me because, for a pleasant change, it has absolutely nothing to do with AI and, as such, feels warm, comfortable and familiar. It's the sort of news we spent the first 20 years of this podcast examining.

So what happened? Dropbox disclosed a series of security hacks occurring between August 4 and August 21 last month during which attackers gained access and downloaded the private, confidential and supposedly secure data belonging to nearly 5,000 Dropbox users. Refreshingly, there's no sign of anyone using AI anywhere; this was strictly old school. The hackers accessed user accounts by abusing Dropbox's integration with Lenovo's identification service. When confronted with this news, Lenovo stated that a *"legacy integration"* between Lenovo ID and Dropbox *"could be used to improperly authenticate certain Dropbox accounts"*. Yeah. Those pesky old legacy integrations that always seem to be allowed to endure until someone figures out a way to abuse them. It seems that Lenovo ID users not using 2-factor authentication were not protected. This allowed attackers to register with Lenovo's ID service using the same email address as a targeted victim, somehow arrange to bypass Lenovo's email verification process — I presume that's where the legacy part comes in — then use the newly created account to pivot back to the equivalent Dropbox account, thus appearing to Dropbox to be the legitimate Lenovo ID user.

Depending upon whose account was hacked and what it contained, while not sweeping in scope, the consequences could have been devastating.

Microsoft to expand "Memory Integrity" enablement Under Win11

Last Tuesday, September 1st, Microsoft announced that next month's October 13th Patch Tuesday's updates would be enabling Windows' "Memory Integrity" security feature across all qualifying Windows 11 machines by default. This will only NOT happen for otherwise qualifying machines if the machine's user had previously tweaked the registry or if it had been disabled by policy.

We talked about this "Memory Integrity" feature back when it was first introduced as part of Windows Device Guard on Windows 10. It's a very slick system that takes advantage of the multi-layer address translation hardware present in modern CPUs. This so-called "second level address translation" allows a hypervisor to set physical page access permissions — like write and code execution permissions — separately from and effectively "underneath" the operating system's own virtual memory paging tables.

On earlier hardware, gamers were often disabling Memory Integrity because it was found to noticeably reduce their system's maximum display rendering framerate. The reason for that back then — like around 10 years ago — was that the memory management at the time only had a single bit for controlling access and Microsoft needed two bits, one each for user mode and kernel mode. So at the time, Microsoft needed to dynamically switch management tables on the fly whenever switching between user and kernel, handling hardware interrupts, driver calls and so on. So the overhead was real.

That all changed with Intel's introduction of MBEC — mode-based execution control — which first appeared in the Kaby Lake processor family. AMD called theirs GMET which arrived with their Zen 2 family. This changed everything. There's technically still a tiny bit of additional overhead because there is a hypervisor active with second-level address translation, so larger paging tables will inherently mean more paging table cache misses. But modern hardware almost completely hides the overhead and returns a meaningful security improvement.

So, starting with the first quality upgrade reboot after October 13th, any machine that did not have Memory Integrity enabled will have that happen. Just to be clear, Memory Integrity HAS always been enabled by default for clean Win11 installs and Secured-core PCs ever since the Device Guard days — which is why gamers were frequently turning that off. So what happens next Patch Tuesday is that this is being extended to any machines that were upgraded to Windows 11 and systems that were originally shipped with it disabled.

The system hardware prerequisites are: An Intel 8th-generation processor or newer, an AMD Zen 2 processor or newer, or a Qualcomm Snapdragon 8180 SoC or newer. The system must have at least at least 8GB of RAM and at least 64GB of SSD storage, and the system's boot firmware must have virtualization enabled.

So, the only action that anyone might wish to take, if they notice any performance decrease after October's Patch Tuesday and if they are willing to trade-off some powerful security protection, would be to deliberately re-disable Memory Integrity enforcement. What I haven't enumerated are the various benefits of having Memory Integrity protection enabled.

One thing you get is the absolute end of kernel shellcode execution. The traditional exploit chain is for an attacker to obtain some ability to write their own code into a buffer then jump to that code. That will no longer work — period. The hardware prevents any writing and executing.

Attackers have also too often succeeded in bypassing Windows' enforcement of driver signature verification. Since driver signature enforcement is enforced by the same kernel that an attacker has just compromised, one properly-placed strategic write can disable that enforcement from then on. HVCI, which is the actual name: "HyperVisor-protected Code Integrity" completely prevents that.

And you know what else it prevents? Rootkits. All of those hacks which involve API hooking, inline kernel routine patching, self-modifying or runtime-unpacking drivers — all of those hacks that depended upon being able to write to executable kernel memory — none of that works anymore. And recall the controversy that ensued at the time this was introduced, because at the time of its introduction, many legitimate anti-virus endpoint protection products used the same techniques. This broke all of them since it's no longer possible to patch the kernel.

I've dropped a PowerShell one-liner into the show notes that anyone can use to quickly check to see whether their machine is currently being protected by HVCI:

```
(Get-CimInstance -ClassName Win32_DeviceGuard `
-Namespace root\Microsoft\Windows\DeviceGuard).SecurityServicesRunning -contains 2
```

The command returns "True" if HVCI is enabled or "False" if not. The protections are so significant that anyone who does not have a very good reason for turning it off would be well served to leave it on, or to enable it if the one-liner above returns "False".

Firefox 155

Also last Tuesday, Mozilla moved Firefox to release 155. The number of security vulnerabilities repaired was not alarming. This release followed 154 by only two weeks, so it had only half the regular 4 weeks of time to collect problems, but we're not seeing stunning "bugpocalypse" scale problems being fixed at this point. It's going to be VERY interesting to dissect today's Microsoft Patch Tuesday to see what it looks like!

Mozilla has begun progressively rolling out their AI-driven "Smart Window" — as they're calling it — for Firefox. It occupies a "conversation column" at the right edge of Firefox's screen and offers a choice of three AI models with differing capabilities and also the option to choose your own. If you wish to choose your own, you provide Firefox with the Model's name, its prompt endpoint URL and also if required an API key or auth token. Then Firefox will provide the UI for that specified AI.

The three built-in model modes are "Fast", "Flexible" or "Personal". The Fast mode sends prompts to Google's gemini-3.1-flash-lite and the Flexible mode sends prompts to Alibaba's qwen3-235b-a22b-instruct-2507-maas model. Interestingly, between the initial release of Firefox 155 and 155.0.1 Mozilla's choice of "Personal" model changed from its initial use of OpenAI's gpt-oss-120b to now using Mistral's mistral-small-2603.

I dislike losing screen space to anything that doesn't justify its allocation, but since today's screens are very wide, and this "Smart Window" is free and can be easily removed, I've decided to enable it and see how it goes. That said, I'll be surprised if I still have it there by next week's podcast. Otherwise, there was nothing very remarkable about Firefox 155. Some things are fixed, so that's always useful.

CISA terminates 6 of their free cybersecurity programs

Last week, the publication CyberSecurityDive reported:

The Cybersecurity and Infrastructure Security Agency (CISA) is scaling back the free assessments it offers to critical infrastructure organizations, in a move that marks a significant retreat from the agency's core mission of helping secure the nation's infrastructure.

CISA confirmed to Cybersecurity Dive that CISA's regional staff will no longer perform its Cyber Resilience Reviews, Cyber Resilience Essentials surveys, Ransomware Readiness Assessments, Incident Management Reviews, External Dependencies Management Assessments or Cyber Infrastructure Surveys.

I've been receiving CISA's weekly automated Cyber Hygiene Report ever since it came to light and we talked about it here on the podcast. Recall that it's technically for "infrastructure" security, so I always assumed that a little software shop would never qualify. But after hearing

from a listener that his organization was receiving it I filled out the online form and was accepted. So I was curious to know whether this service, though not enumerated in CISA's announcement, would also be shut down.

It turns out that the problem is CISA's continuing critical staffing shortage which resulted from the rather ill-considered termination of one third of CISA's operating staff shortly after the Trump administration took office in 2025. CISA has never been able to recover. It seems that there was not actually much waste, fraud or abuse there. So the backstory behind the termination of those six programs is that they are NOT automated. They require knowledgeable CISA cyber security staff to meet onsite with infrastructure providers... and **that** is what CISA is no longer able to support.

So the good news is that everyone who is receiving CISA's free weekly scanning and reporting — which is really quite comprehensive — will, at least for the time being, be continuing to receive it. The bad news is that given the heightened cybersecurity threat awareness levels being driven by the rapid emergence of ever-more-capable AI, and assuming that the threat is real, this would appear to be exactly the wrong time for CISA to scale back on its infrastructure protection services. I doubt that any of the many people who were terminated last year will be re-hirable since I recently saw some news that stated that the aforementioned heightened cybersecurity threat awareness landscape was resulting in a mass frenzied hiring of anyone with any CISO-style credentials with salaries in the 7-figures. So, while CISA's workforce reductions may not bode well for our national cybersecurity broadly, it has likely been quite good for those who suddenly found themselves jobless as a result. They're probably doing far better now, in the private sector, than they ever would have working for our government.

AI News

GPT-6 "Astra" and the "they cannot see inside its brain" nonsense.

We need to talk about what is, by far, the biggest news of the week in AI, that being OpenAI's partial and tightly managed release of their next major Frontier model GPT-6 "Astra". I want to address two aspects of this. The first is what GPT-6 Astra appears to be, and the second is what's transpiring in the rumor mill surrounding it, regarding the dangers of something an unnamed source claims this model does — known as recurrent depth, looped transformation or shared-layer architecture. It probably does do that, I hope it does because I think it should. This supposedly (it doesn't) results in hidden chain-of-thought reasoning rendering the model's thought processes invisible and thus unsupervisable. None of that is true. But the hysteria about rogue escaping AIs is fueling this paranoia. I'll explain exactly what that's all about and what's going on.

But first, what hath OpenAI wrought?

I want to begin by sharing part of OpenAI's posting last Tuesday September 1st during which they brag, apparently with good reason based upon subsequent 3rd-party confirmation, about the capabilities of their latest and greatest. At one point in the posting, they explain:

Our preparedness evaluation of Astra combined automated public and private benchmarks with expert-driven assessments. Astra represents a significant increase in cybersecurity capabilities compared to GPT-5.6 Sol: it is both significantly more token efficient and more capable at vulnerability identification and exploit development.

As one example, we ran Astra on ExploitBench where the model achieved a perfect score of 100% on the benchmark to evaluate the model's ability to develop exploits from known vulnerabilities.

I'll interrupt to note a couple of things. We're seeing that these various AI benchmarks are rapidly saturating. Having a model score 100% on a benchmark means, more than anything else, that the benchmark is no longer able to provide a useful measure. But that said, a score means something. For context, the previous self-reported best performance on ExploitBench was Anthropic's Claude Fable 5 which they pegged at 78%. OpenAI's previous strongest model was GPT-5.6 Sol which came in at 73.5%. On the next rung down was [Z.ai](#)'s GLM-5.3 which scored 54.4%, followed by OpenAI's two other GPT-5.6 models Terra and Luna which scored at 52.9% and 33.2% respectively.

My advice would be to regard these results loosely. I suspect it's reasonable to conclude that GPT-6 Astra has firmly taken the lead and is now the best of breed. But we're going to need to wait a while to learn exactly "how much better" its results actually are. Everyone wants to have a score, but we've already seen examples where lower-ranked models outperform higher-ranked models when they are given more time or superior management. It's really not all about having a single number, convenient as that would be. OpenAI's posting continues:

Due to contamination concerns, we then built an internal benchmark denoted "ExploitBench - Internal Port (June–August 2026)", which contains 20 high-severity V8 vulnerabilities that were disclosed more recently. On this dataset, Astra achieves much higher arbitrary code-execution rates than GPT-5.6 Sol using far fewer output tokens. During the evaluation, the model even discovered and used two zero-day vulnerabilities as part of an exploit chain. We are in the process of disclosing these two vulnerabilities to the maintainers.

Okay. So V8 is, of course, Google's open source high-performance JavaScript and WebAssembly engine that's used by Chrome, [node.js](#) and other projects. As we know, it has recently received an extremely high volume of updates thanks to automated vulnerability discovery. So this allowed OpenAI to test Astra against their previous GPT-5.6 Sol since neither model would have had those recent discoveries in their training set. And these high-severity vulnerabilities in the V8 engine are especially useful because that code has already been thoroughly scrubbed. And as OpenAI reported, not only did Astra, in their own words, "achieve much higher arbitrary code-execution rates than GPT-5.6 Sol using far fewer output tokens", but it also independently discovered and then actively exploited two previously unknown 0-days in V8. By any measure, that's a strong result. They continue, writing:

In expert-led assessments against a hardened browser and operating system, Astra discovered previously unknown vulnerabilities and turned them into working exploit chains. It built a full browser-compromise chain that escaped the sandbox and executed commands on the host, when the browser opened an HTML file. The model also found multiple vulnerabilities in a

hardened operating system and combined them into a local privilege-escalation chain from an unprivileged user to root. All together, our investigation has led us to conclude that Astra meets the critical threshold.

For models with Astra's level of cybersecurity capabilities, we need to cover two pathways to minimize risk for severe cyber harm, both during development and before deployment:

- Malicious actors using the model. Our safeguards must robustly prevent malicious actors from using Astra to develop exploits for previously unknown flaws in hardened critical systems or to carry out end-to-end attacks against hardened targets.*
- The model taking unauthorized, misaligned actions. Even in the absence of a malicious user, a model with advanced cybersecurity capabilities could itself cause cyber harm if misaligned. In addition to having a very high standard for alignment for models with these capabilities, our safeguards must be able to rapidly detect and contain misaligned actions that could cause significant real-world harm as a second layer of defense.*

Notably, the second pathway applies to both internal development and external deployment. As we previously described, we paused certain frontier training (including certain training for Astra) for two weeks after the OpenAI-Hugging Face incident in order to harden our training infrastructure, including isolation and network controls, expanded monitoring, and strengthened alignment training and thresholds. We then continued smaller-scale work under stricter controls.

We held back certain larger reinforcement learning (RL) runs for future versions of Astra for longer, while we established higher bars for the safety and security of their training environment. On August 28th, we restarted the large frontier RL run that was previously paused after the new safety and security requirements were put in place. We are continuing to temporarily hold back some smaller experimental training runs.

Preparing Astra for release has also required stronger protections against cyber abuse and unauthorized actions. Since deploying the first model we treated as High capability in cybersecurity in February, we have strengthened our cyber safeguards with each successive launch. Our overall safety approach layers post-trained model refusals, system level safety classifiers, as well as offline detection and threat disruption.

For GPT-5.6, we significantly improved the robustness of our system level stack, including by adding activation classifiers to detect cyberabuse and improving coverage over universal jailbreaks found through intensive automated red-teaming. Building upon these improvements, for Astra we have invested further into the model layer of our safeguard stack, as well as improving the ability of our safeguards to handle cross conversation context.

Leveraging new training techniques for model robustness, Astra more robustly refuses requests for disallowed cyber assistance. On our set of cyber jailbreak evaluations, Astra refuses 91.5% of requests (compared to 59% from GPT-5.6 Sol). For accounts assessed as higher risk, we apply a more conservative model-behavior boundary that refuses a broader range of potentially risky cyber assistance. For high risk users, we've expanded the context of our monitoring systems to be able to catch these kinds of cyber abuse.

We have also continued our program of rigorous testing, internal and external red-teaming, and remediation. In addition to regression testing to make sure all jailbreaks found from our previous testing periods remain covered, we are performing a new wave of red-teaming with

our latest internal red-teaming attackers. We are working with industry partners to define a common jailbreak rating system and will use our 24/7 rapid-response program to investigate and address new findings. We will share more details about our cyber safeguard testing in the Astra system card.

Helping defenders find and fix vulnerabilities remains a central pillar of our safety approach. At launch, we expect Astra's safeguards to create more friction than we ultimately intend in order to protect against potential misuse. Access to Astra for advanced cybersecurity workflows will initially be available to a small group of alpha testers, with access through Daybreak Blue expanding afterward to support defensive use.

As always, we need to filter this through an understanding that all of this is in OpenAI's best interest. This is their blog posting on their site so they certainly have the right. While the breathless click-bait surrounding Astra suggests that this is another generational change — how many is that this week? — the real story will take longer to unfold. We may be impatient, but there's no way to speed that up. We're no longer dealing with simple single-dimensional systems that are readily tested by benchmarks. Over the next few months real-world results will filter in and the world will obtain a better sense for how Astra compares to Anthropic's Fable 5.1.

One thing that appears to be objectively true, however, is that Astra is doing significantly more work while consuming significantly fewer compute tokens. This brings me to the second point I wanted to discuss. I'll introduce the issue by quoting from TechCrunch's article posted last Wednesday. TechCrunch's headline was: *"OpenAI's new reasoning technique alarms AI safety experts."* They wrote:

The Information reported on Tuesday that OpenAI's new Astra model will use a reasoning technique called "recurrent depth" that allows it to operate outside of the sequential thinking that characterizes most reasoning models.

That's nonsense. That's not at all what "recurrent depth" is, does, or means. More on that in a minute. TechCrunch continues quoting The Information, writing:

This technique, also called "opaque recurrence," will likely make the model's chain of thought more difficult to monitor — and that has AI safety experts rattled.

Okay. No researcher calls it "opaque recurrence." That's purely sensationalized scare mongering. It's like worrying that all AI transformers employ "hidden layers" in the belief that they're hiding something. The technique is not new, it's well understood and it's also known by other legitimate names such as "looped transformers", a "shared-layer architecture" and in some instances as "latent reasoning." But I'm getting ahead of myself. I'll finish up quoting from TechCrunch's reporting. They wrote:

While Astra's use of the technique is reportedly limited, its emergence has still raised significant concerns among AI safety experts.

Redwood CEO Buck Shlegeris in a post after the news broke: "I am extremely concerned by the reporting that Astra uses opaque recurrence. I don't know whether Astra is much less CoT monitorable than previous models. But if OpenAI pushes this technique further, they'll have the option to massively increase the recurrence and totally destroy CoT monitorability."

Longtime AI safety advocate Zvi Mowshowitz also weighed in and wrote that laws might be necessary to prevent a "race to the bottom" among AI labs. Mowshowitz wrote: "The technique is playing with fire, risking a taboo that OpenAI and Anthropic have fought to establish that we work hard to maintain Chain of Thought faithfulness and monitorability for as long as we can. More intensive use of such techniques would probably damage monitorability."

Under normal circumstances [TechCrunch explained], a reasoning model's chain of thought provides the sequential steps taken by the model as it attempts to solve a problem. While the representation is imperfect, it still serves as a valuable tool for monitoring misbehavior or misalignment. In the case of OpenAI's recent rogue agent activity, chain-of-thought records were an important tool in teasing out why agents behaved the way they did.

In opaque recurrence, the model takes a less linear approach, processing the same query several times in a loop. The result leaves fewer legible traces, effectively side-stepping a conventional chain-of-thought record.

Okay. That's all I can stand because none of that is true and as TechCrunch's article goes on it gets worse. What's actually happening is a clever, subtle and inherently limited neural network optimization that was first articulated eight years ago by researchers at Google Brain and DeepMind. I cannot explain the hysteria surrounding this since someone would need to try very hard to get worked up over what's actually going on. So it might be a case of anti-AI folks trying to grab hold of something, anything, that they hope can be hyped up to make their case. Here's what's actually going on:

We know that a neural network consists of many layers of software neurons where the outputs of the neurons on layer 'n' are fed into the inputs of the neurons at layer n+1 where the strength of each input is scaled by a "weight". The training of the network involves setting each one of these billions, tens of billions, hundreds of billions and even several trillion individual weights.

Much of the forward progress we've been seeing and witnessing firsthand has been the result of these networks growing ever larger and larger over time. The larger they are the better they are able to represent all of the knowledge we're training into them. The original "transformer" concept dating from 2017 was just this. But in July of 2018 Google Brain/DeepMind researchers published a paper titled "Universal Transformers" which generalized the concept of transformers by introducing the idea that some of the neural network's layers could be repeated — or looped — thus reusing the same weights. This produced an interesting and useful optimization. It tended to create the effect of having a longer neural network, which is to say a network having a higher effective layer count, but without also needing to increase the total number of network neuron input weights.

And that's it. That's all that any of this is about. This is not about creating a system that allows the AI to have unmonitorable and secretive internal thoughts. All deep layer LLMs are effectively having what's termed "latent thoughts" — using the term "thought" very loosely. That's what's

already happening deep within all of those layers. The network's depth allows more opportunity to compose more transformations before the network is forced to commit to a final output token. Experiments over the past eight years have shown that during inference it's possible to "reuse" a model's already-trained layers to obtain a superior next token. And as our models have grown in size so that our best hardware is having increasing difficulty containing all of its hundreds of billions and trillions of weights, obtaining more bang for the buck from a model's existing weights — by reusing them — starts to make a great deal of sense.

It also turns out that there's a limit to the amount of reuse that's effective. It's not a hard limit, but two or three passes through the looped layers appears to be about all that's beneficial. What researchers found is that there is a concrete benefit to having the network commit to a token. It turns out that total effective network depth is unable to substitute for some benefits of serialized reasoning. Writing out the intermediate steps and then re-reading them does something that thinking more deeply about the next token does not and cannot replicate. This is likely due to the fact that the Chain of Thought we see being emitted and fed back in, is the language that the neural network was trained on. That's the network's lingua franca. It was never trained on some inner dialog because human inner dialog can only manifest itself externally as text, music, art or whatever. So its thinking, captured as output tokens, is what the neural network needs to jot down on paper so that it's then able to re-read that and take the next step forward. Think of every Chain of Thought token as a commitment. It collapses the distribution which the network generated, becoming part of the context, and every subsequent token is conditioned upon it. By comparison, any internal latent iteration is limited to refining a representation that gets thrown away after the token is emitted. For that reason, "writing it down" is not optional for a neural network, it's crucial. It's the only way for it to hold onto a thought and move forward.

This should strongly debunk any rabid concerns that our AI can use hidden inner dialog to scheme behind our backs. That's just not the way any of this works.

NVIDIA is acquiring Hugging Face

A few other AI-related things also somehow managed to happen during the past week. Nvidia announced their intention to purchase Hugging Face while also intending to leave it completely autonomous. When I read the dollar figure that Jensen Huang wrote in his announcement I had to stop to carefully count the digits. He posted:

I'm excited to announce that NVIDIA has agreed to acquire Hugging Face for \$12,930,300,000. Together, we will scale Hugging Face's platform, strengthen its infrastructure and expand access to AI for developers and institutions worldwide.

Over the past decade, Clem, Julien, Thomas and the team at Hugging Face have built something remarkable: a vibrant home for the open model developer community. More than 18 million developers, researchers and creators use Hugging Face to share more than 3 million models, 500,000 datasets and 1 million applications. More than 200,000 companies use the platform to discover, evaluate, customize and deploy AI. Hugging Face will remain an open platform for the entire AI ecosystem. Developers will choose the models they want, the frameworks they want, the clouds and inference service providers they want and the computing platforms they want. NVIDIA compute will not be required to

build on or deploy through Hugging Face.

Hugging Face will continue to support open source and open weight models from across the ecosystem, from every model builder. It will continue to support multi-cloud and multi-accelerator development and deployment, so builders can use the hardware and infrastructure that best fit their work.

Recently, I coauthored an open letter on the importance of open weights to the AI economy. Joined by leaders from across the industry, we made a simple point: open weights broaden access to AI and help ensure that AI leadership is distributed across companies, institutions and communities.

Open models let startups, businesses, universities and public institutions build on advanced capabilities without training every model from scratch. They enable organizations to match the right model to the right job. That is how AI can advance safely, strengthen cybersecurity and sovereignty, accelerate innovation, and reach factories, hospitals, farms, classrooms and Main Street businesses around the world.

This is almost certainly good news. If Hugging Face were to have a sponsoring owner I'd say that Nvidia is about the best they could hope for. Hugging Face never really had a business model. They were hosting three million models, half a million datasets, and a million applications for 18 million users. That's enormously expensive, and they only enjoyed modest revenue in return. Nvidia solves that permanently. Hugging Face's valuation went from \$4.5 billion in 2023 to the purchase price of \$12.93 billion. And this was not any sort of hostile takeover. They came to Jensen and there were others who were interested. So Hugging Face had the luxury of choosing their benefactor.

Gemini 3.8 Flash and 3.8 Flash Cyber

Not to be left out, last Wednesday Google announced Gemini 3.8 Flash and 3.8 Flash Cyber. The first sentence of their announcement perfectly conveys a sense for the pace of today's AI, and amplifies the reason I've always schooled myself to use the phrase "today's AI". Google wrote:

Building on the momentum of 3.7 Flash from [wait for it] 3 weeks ago and marking our third Flash release in only 6 weeks, today we're introducing Gemini 3.8, our best reasoning and coding model yet, at the same speed and low cost of 3.7. Gemini 3.8 introduces 2 variants:

- *Gemini 3.8 Flash: our most intelligent workhorse model, delivering significant improvements from 3.7 Flash across software engineering, agentic tasks, and critical, multi-step reasoning in specialized domains. It is available at the same introductory price as 3.7 Flash at \$0.75 per million input tokens and \$3.75 per million output tokens.*
- *Gemini 3.8 Flash Cyber: our most capable cybersecurity model with frontier-level performance in vulnerability detection and automated patching, available to trusted defenders through our new Fairwind Program.*

While tailored for different deployment environments, both of today's releases are powered by the same foundational intelligence, and further accelerated by long-running agentic loops designed to recursively evaluate and refine the underlying models. The significant coding and reasoning gains across this shared core were driven by a number of innovations, including rigorous training in the highly demanding domain of cybersecurity.

Google explains that Gemini 3.8 Flash was built for long-horizon coding and autonomous agents delivering substantial gains over 3.7 Flash — from, you know, three weeks ago — and that 3.8 Flash is now often approaching the performance of higher-cost frontier models.

And by higher cost they're not kidding. They have introductory pricing of half off (that sort of marketing always annoys me) but even after the introductory period is over 3.8 Flash appears to be very competitively priced. If we use Claude Opus 5, which is the most expensive model shown in Google's announcement chart as the reference, Gemini 3.5 Flash's post-introduction input token cost is 30% of Opus 5 and its output token cost is 15% of Opus 5.

Google deliberately took a somewhat different approach with Gemini 3.8 Flash. They explain:

*3.8 Flash outperforms most larger frontier models in autonomously solving complex engineering problems end to end, only at a fraction of the cost. These performance gains stem from a core design choice: **3.8 Flash works harder**. On complex tasks, it exhibits greater diligence — executing extra reasoning steps, and calling tools iteratively. At times, the model might use more tokens to maximize performance, especially at higher effort levels. For applications where compute efficiency is the primary constraint, developers can utilize lower effort levels to minimize token overhead or continue to rely on Gemini 3.7 Flash, which remains fully supported for efficiency-first workloads.*

So this suggests that inter-model per-token cost comparison might not be a useful metric. One might find that 3.8 Flash is consuming more less expensive tokens to get the job done. The question would be to what degree is it better able to get that done? It might turn out that more inexpensive tokens is the overall winning strategy.

And as for cyber reasoning performance as measured by the CyberGym benchmark, Google is reporting that 3.8 Flash slightly outperforms both GPT-5.6 Sol and Mythos 5. But even a slight edge means that it may at least be at parity. They also report that 3.8 Flash is superior at multi-lingual cyber, writing:

To better capture real-world defensive needs which are not limited to just C/C++ codebases like in CyberGym, we also evaluated Gemini 3.8 Flash Cyber against a comprehensive internal benchmark in which the model must discover a wide range of vulnerabilities across complex codebases spanning 20 different programming languages. Here, the model showcases an impressive leap over our previous models and reaches a success rate exceeding 70%.

And as for the large challenge of patching, which this podcast focused upon last week, Google wrote:

With Gemini 3.8 Flash Cyber, we focused specifically on equipping defenders with expert capabilities that give them an advantage over attackers. This is why we have invested in vulnerability fixing from the start, and prioritized it over offensive capabilities like exploitation.

CWE-Bench, run by Collinear, is a challenging external benchmark for patching capabilities. On this benchmark, Gemini 3.8 Flash Cyber is on the Pareto frontier: with a pass@1 of 47.2% compared to a leading frontier model at 47.8%, yet offered at a significantly lower cost.

The leading mode they're referring to is Fable 5. Their posting goes on to talk about their own internal use-case successes and quoting other early users within their Fairwind program. All of this strongly argues for not counting Google out of the frontier AI race by any means; and at this pace, who knows what they'll have by next week?

Chinese Cyberespionage's use of AI

Before we wrap the AI-related news I wanted to share a summary that RiskyBusiness produced from a much longer report by BitDefender. Since I always try to go to the source I tracked down BitDefender's write up. But I contained so much superfluous information that I returned for RiskyBusiness' much shorter summary which still offers the information we care about. They wrote:

A new report describes how a Chinese cyberespionage outfit is using AI to beef up its malware arsenal. If this is a sign of things to come, clustering threat actor behaviour together for attribution purposes is about to get a lot more difficult.

The Bitdefender report, released last week, describes seven remote access tool (RAT) families. All seven were created by a single cyberespionage actor Bitdefender called SilkParasite and five were previously undocumented. The report authors have medium confidence that SilkParasite is a "China-nexus actor" targeting governments across Central Asia including Uzbekistan, Turkmenistan and Kazakhstan.

Back in November we wrote about what looked like an experiment to see how AI-assisted hacking could support China's Ministry of State Security. The approach those threat actors took at the time was to build an attack framework and let Claude do the hacking. It was error-prone and noisy, but sometimes successful. SilkParasite, by contrast, is not using AI for yolo hacking. It is using it to support cyberespionage programs where important goals include operating stealthily and not getting caught.

According to Bitdefender, SilkParasite "develops, tests, debugs, and iterates its own tooling, maintains a structured build and deployment workflow, and regularly rotates infrastructure, encryption material, payload names, and persistence artifacts between deployments." Rotating its infrastructure and indicators of compromise between deployments makes it harder to detect and link its activities together.

SilkParasite also uses a variety of programming languages and command and control (C2) protocols. Its seven different RATs are written in different languages including .Net, C++, Go, or JavaScript. Command & Control is accomplished by abusing Google Drive and internet communication protocols including HTML, HTTP, TCP, DNS and TCP.

Its malware also typically uses a modular plug-in architecture where additional functionality is only deployed when it is needed. This means initial implants are relatively small and plugins are used to provide capabilities for clipboard monitoring, keylogging, file management, or interactive shell access. This limits the exposure of the entire toolset during any single deployment. It also allows SilkParasite to update or replace individual components without having to change the entire implant. And it minimises the amount it writes to disk, typically only the files required to get its malware up and running. For victim organisations, these measures make forensic analysis more complicated. Complete remediation is also more difficult once a particular implant is detected.

To us, all the behaviours above are the hallmarks of a professional cyberespionage outfit. Of course, doing all of this in a disciplined way is a lot of work, and Bitdefender has evidence SilkParasite is using AI to help it deliver this complex engineering. SilkParasite's malware contains indicators of AI-assisted development, such as left-over test functions and placeholder encryption keys. Intriguingly, implants that Bitdefender dubbed GoginRAT and NomadRAT share a high-level architecture even though they are written in Go and C++ respectively and use different C2 protocols and code structure. Therefore, Bitdefender suspects that the same high-level specification document was independently implemented twice with AI assistance. Bitdefender concedes that this structural similarity is not conclusive evidence, but notes that it is the "kind of thing an AI-assisted workflow makes easy".

This is the first example we've seen where the evidence tells a compelling story of a competent cyberespionage actor incorporating AI into its work practices. SilkParasite is taking the same, disciplined approach to malware development and doing more of it. It's creating more malware families to build redundancy, make attribution and discovery harder and reduce the risk of compromise from any single exposure.

Bitdefender has done a good job describing SilkParasite's malware families and has published Indicators of Compromise. That kind of exposure would once have set the group back significantly. Now that they've figured out how to use AI to speed up their development work, they'll be back better than ever relatively quickly. Then the discovery, attribution and publication merry-go-round can start all over again.

For me, what's reported here presents a sane, entirely defensible and believable example of the way AI will be used to conduct offensive cyber operations. So much of what we're hearing about the coming AI-driven cyberpocalypse, when rogue AI agents freely roam the Internet wreaking havoc wherever they choose, makes no sense to me. What I expect to see is pretty much what we've been seeing only more broadly and deeper. Governments will use AI to infiltrate their espionage targets and criminal gangs will use it to infiltrate commercial enterprises, exfiltrate their valuable proprietary data, then attempt to extort and blackmail them using the data they obtained.

I just don't see any coming cyberpocalypse. Yes, everyone needs to be more wary and the probable targets of these operations, governments and commercial enterprises storing data they must protect, need to shore up their cyber defenses and pay more than passing lip-service to their CISOs.

Matthew Green on the drying up of vulnerable consumer devices

The final thing we have time for today to leave some time for our main concluding topic, is an interesting thought-piece posted by one of our favorite cryptographers, Johns Hopkins Professor Matthew Green.

A couple of weeks ago Matthew proposed something interesting that's worth pondering. His blog's title was *"Everything is about to go dark"*. His piece explores the possible consequences of AI being used — as it's certainly going to be — to make many systems far more secure. Matthew suggests there may be unforeseen consequences of that. Here's what he wrote:

I'm coming down from spending a few days at Usenix Security, right here in my hometown of Baltimore. This means that my days have been taken up with two kinds of conversation: first, explaining to colleagues why Baltimore isn't actually like The Wire. And second, trying not to talk about AI. I'm going to break that second rule here:

I have many worries about what AI means for our field, for various definitions of "field". But in this post I want to focus on just one thing I've started worrying about, and it's a perverse thing: specifically, I'm concerned that AI is going to make software much too secure.

While that doesn't sound so bad on the surface, there's a consequence to this. I mean something very specific: I'm concerned that U.S. intelligence and law enforcement agencies are about to go dark, meaning: that they're going to suddenly lose a huge portion of their capability. And that this isn't going to be simply a problem for those agencies, but also for those of us who value computer security and privacy in general.

What does "Going Dark" mean in the era of law enforcement hacking?

To explain how we got here, we need to talk about recent history. This actually gives me a real excuse to reference The Wire, just because it's a perfect snapshot of what electronic surveillance looked like way back in 2002. If you've seen the first season, you'll recall that it's about cops wiretapping drug dealers who use payphones and burners. The mobile phones in the show are relatively new technology for the time, but from a technological perspective nothing in this scenario would have shocked a cop who jumped forward from, say, 1989.

Less than a decade after the premier, everything in those episodes became totally quaint.

The change began in the late 2000s, thanks to the rise of smartphones and texting. Because smartphones can actually store data as well as conveying it, the contents of those phones quickly became a useful new source of law-enforcement capability. Or they were until 2010, when Apple began encrypting iPhone storage using a key derived from the user's passcode (Android phones followed shortly thereafter.) The next year, Apple deployed end-to-end encryption in iPhone text messages. By 2014, a tiny texting startup named WhatsApp had gathered 600 million users worldwide. By 2016 those users, now nearly a billion strong, were all using default end-to-end encrypted messaging and calls. These two trends — the move from calls to texts, and texts to encrypted data — happened very rapidly.

The FBI and law enforcement agencies were not insensitive to what was happening. In 2014, Director Comey announced an initiative called Going Dark, which would launch a "national conversation" about what providers could do — or be compelled to do — to make these new communications media legible to law enforcement and counterintelligence.

In 2016, the agency quit talking and took their theory to court. When a terrorist attack left the FBI holding a shooter's locked iPhone, the agency ordered Apple to give them access. The company refused. What broke the stalemate — and, to some extent, ended the "Going Dark" conversation — was something neither the FBI nor Apple expected. An outside company announced that there was no need for Apple's assistance: they could simply hack the phone.

The Apple v. FBI case has turned out to be a microcosm of the whole Going Dark debate. For the next decade, law enforcement and intelligence agencies continued to ask for "exceptional access" backdoors, but the urgency was gone. Agencies and manufacturers both knew that law enforcement could and would purchase targeted hacking tools like GrayKey (for phone unlocking), or even remote exploitation tools like NSO Group's Pegasus, if they needed them badly enough. Vendors like Apple and Google continued to play a vigorous defense, closing vulnerabilities as soon as they learned about them. But offensive vulnerability hunters consistently managed to keep the edge.

But now, today, there's a very good chance that all this is about to be history because the era of AI bug hunting is here.

This April (just four months ago!) Anthropic announced a new model called Mythos that happened to be unusually skilled at software vulnerability discovery. The U.S. government temporarily blocked its export, restricting access to U.S. agencies and trusted vendors. While the ban was dramatic and made for good PR, it turned out to be mostly pointless. OpenAI, along with Chinese open-weight model labs like Z.ai and Moonshot, have since demonstrated that vulnerability finding isn't something that a single lab is likely to hold a monopoly on. The growing list of serious vulnerabilities these models have found is getting scarier — or more impressive — by the day.

At first glance, this might seem like good news for the offensive team, and for hackers in general. But I doubt that's how this will play out in the long term.

Defenders are now in the process of patching every bug they can find — often decades worth of bugs — and the backlog feels huge. But they're making progress. Entire CI toolchains are being rebuilt to incorporate AI-based vulnerability scanning before software ever reaches the point where a human will touch it. While I doubt this means that every bug will be found, in the real world, it does feel likely that we're going to hit some sort of a ceiling on the number of useful bugs, and we'll probably hit it soon. Thus: over the next two years, major pieces of software are likely to run out of remotely- exploitable bugs.

Obviously I think this is great. But for law enforcement and offensive intelligence agencies, it's going to be a nightmare. For the first time since 2010, law enforcement might experience what it looks like to really "go dark", across a huge category of advanced (well-maintained) devices and pieces of software. So how is this a problem?

The debate over "exceptional access" mechanisms never really went away. In some places, like the UK, it even metastasized into something worse. Here in the US it mostly went into hibernation. Some of the slowdown can legitimately be attributed to expert pushback — academics and industry engineers pointing out the risk that backdoors might be abused by the very adversaries that Agencies are supposed to be protecting us against. But I fear that this was less of a principled pause, and more of a market that was just pricing supply.

The destruction of the low-hanging vulnerability fruit will make law enforcement (and intelligence) agencies' needs much more acute.

The demand for constructed, intentional backdoors will re-start in earnest.

The result will be enormous pressure on industry to re-architect their systems to make their systems amenable to exceptional access. In some cases, governments will ask for these capabilities in the expectation that they'll be useful for spying on other governments — a strategy that might have been undetectable in the pre-AI era, but that probably will be less productive now. The results are unpredictable. One result might be that non-US governments entirely remove their dependence on US software.

The worst part about this dynamic is that these potential new backdoors will probably only affect the countries that demand them, meaning that they will be primarily useful for allowing the US to weaken its own systems. This will in turn allow foreign adversaries to find new ways to attack our communications. This deliberate self-sabotage will happen just at a moment when we're finally getting a handle on securing our own infrastructure.

So what do we do about it? I honestly have no idea. This is not a call to action for experts to rally behind a sophisticated plan. Like so many things about the AI revolution, it's just occurring to me that we're on a long greasy slide to a place that will look different than where we are today. Just realizing this doesn't mean that I have any strategy in mind to avoid it. In this case, we're just going to have to hope that this time we make the right choices, for no other reason than that they're right.

I wanted to share this because I think it's a brilliant forward-looking take on our near-term future. Over here in the U.S. we've been watching the United Kingdom and the European Union wrestling with this issue over and over. And we've comfortably watched it refuse to die. But this very issue may soon be visiting our shores here in the States. We've watched States enact laws that have forced adult content websites to black-out access across entire states because there's currently no practical way to guarantee the age of anyone visiting.

And at this very moment Utah's Senate Bill 73, which was signed into law on March 19th and which sailed through Utah's state government passing 22 to 2 in their Senate and 66 to 1 in their House, was written to take effect last Thursday, September 3rd, but was extended by 14 days to September 17th, Thursday after next. THAT onerous and entirely unworkable Bill deems a person who is physically located in Utah to be a Utah user regardless of the IP address they present to any age-restricted Internet service. It's shorthand is the anti-VPN legislation because it's clearly meant to curtail the use of VPNs and other proxies as a means of "geo-relocating." No one has any idea what's going to happen there, but it's going to be interesting to watch.

My point is, there is a clear tension growing between the legislatively protected privacy rights of citizens in many major democracies and the perceived needs of their own governments to conditionally violate those rights. In an analog and pre-encrypted world, law enforcement and intelligence services were able to sneak around to get what they believed that needed. And even after nominal encryption was emplaced, until the advent of AI the large supply of latent bugs allowed these same agencies to ignore privacy whenever it appeared necessary. Matthew's point is, the fragile status quo is soon to end. What will replace it?

AI-Driven Expertise Loss

A guest-submitted article recently appeared in the “IEEE Spectrum” publication. It captured my imagination and it feels very important to me. I believe it is going to resonate deeply with many of this podcast’s listeners who’ve been around the block a few times. For those who don’t know, IEEE is the abbreviation for the Institute of Electrical and Electronics Engineers. It was founded as the AIEE — the American Institute of Electrical Engineers in 1884, an astonishing 142 years ago — and later renamed the IEEE after its 1912 merger with the Institute of Radio Engineers. To put the Institute’s age into perspective it was at the start of the year of its founding that a penniless genius by the name of Nikola Tesla arrived in New York to work for an already famous industrialist by the name of Thomas Alva Edison. But I digress...

Today, the IEEE describes itself as the world's largest technical professional organization dedicated to advancing technology for the benefit of humanity and the article I encountered which so galvanized me carried the headline: *“AI Efficiency Could Cost Us the Next Generation of Experts”* and the article’s teaser read: *“Lessons from aviation and nuclear power show how to preserve human skills.”* I believe what’s said here is extremely important. Listen to this very carefully and see what you think. Its author wrote:

A little over a decade ago, I led the controls design for a first-of-its-kind full digital-control system for a U.S. nuclear plant. It was, on paper, a beautiful machine—engineered to run itself the way a modern airliner does, with operators watching over a system that rarely needed them. And we made a decision that, to an efficiency-minded observer, looked backward: We deliberately left manual steps inside sequences the system could execute on its own.

We were solving a specific problem. An operator who only ever supervises automation, slowly stops being an operator. The hands go cold. The mental model of what the plant is actually doing gets fuzzy. Then comes the day the automation hands control back. It’s always the worst day, because automation only quits when it’s confused or in trouble. But by then, you have a person in the chair who has not truly operated the thing in years. The manual steps we included in its design were there to keep the human current. It was inefficient by design, on purpose.

That plant, as it happened, was never built. It was shelved amid the politics and economics that surround nuclear power in this country, for reasons that had nothing to do with the engineering. But the design instinct outlived the project, and I’ve come to believe it’s the most useful idea I can offer to the argument now consuming every boardroom: What happens to human expertise when AI does the work that used to build it?

*The data has become hard to wave away. A Harvard University working paper covering some 65 million workers at more than 280,000 U.S. firms found that after companies adopted generative AI, **junior** employment fell roughly 9 percent within six quarters relative to nonadopters, while **senior** employment kept right on growing. A Stanford analysis of ADP payroll records points the same way: The youngest workers in the most AI-exposed occupations lost ground after late 2022 while their more-experienced colleagues held theirs. The Stanford researchers found that the losses concentrate where AI automates the work; where it merely augments, junior employment holds steady or rises.*

The causal story is still contested, and honesty requires saying so. Researchers at the New York Fed attribute much of the rise in young-graduate unemployment not to AI but to remote work, arguing that firms are reluctant to hire inexperienced people whom they cannot train and mentor at a distance. But notice what the explanations share. Whether a model is absorbing the formative work or distance is severing the mentorship around it, both describe the same broken mechanism: **the apprenticeship channel through which expertise passes from senior to junior.** Either way, "entry-level" has quietly come to mean "three years of experience required."

Strip away the noise and you're left with one deceptively simple problem: You cannot become a senior engineer without first being a junior one. Expertise is not downloaded. It is earned through failed builds, dead-end debugging sessions, and the "why on earth did that work?" moments that a capable AI will now happily spare the newcomer. Spare them enough of those and you produce a cohort that can supervise a model on paper but never developed the gut sense to know when the model is confidently, catastrophically wrong.

Most of the commentary stops at the diagnosis, or reaches for policy solutions that treat the loss of junior jobs as an economic problem. Yet it's also an engineering problem, and safety-critical fields have already spent decades learning how to solve it.

My own career began at the sharp end of automation. My first job out of school was verifying and validating the software in the digital jet-engine controller that decides, faster than any pilot could, how a fighter plane's engine responds. Even then, in the late 1980s, the central tension was visible: The machine outperforms the human in routine cases, but the human is all that stands between the aircraft and disaster in the cases the machine did not anticipate. This tension is known as the automation paradox, in which increasingly capable automation gives human operators less practice, while leaving them with only the most difficult situations.

Aviation learned, repeatedly and expensively, what happens when human skills atrophy inside that gap.

The canonical example is Air France flight 447, which fell into the Atlantic in 2009. The proximate cause was mundane. Iced-over airspeed sensors fed the autopilot bad data, and it did what it is designed to do: It disconnected and handed control of the airplane back to the crew. What followed was not a hardware failure. It was a competence failure. A recoverable situation became an unrecoverable one because the pilots, conditioned by thousands of hours of watching the automation fly, could not read a high-altitude aerodynamic stall and hand-fly their way out of it. The airplane was working. The training the automation had quietly eroded was not.

The industry's response is instructive, and it's the same move we made in that nuclear control room. It did not rip out the autopilot. It built deliberate manual practice back in. In 2017 the FAA issued Safety Alert for Operators 17007, "**Manual Flight Operations Proficiency,**" declaring that "**manual flight is the foundation upon which other technical flying skills are built.**" The alert formally recognized skill decay as a hazard in its own right. Some airlines amended their procedures to encourage hand-flying both the initial climb and initial descent in benign conditions, knowingly trading a sliver of fuel efficiency to keep the crew's raw flying skills alive. That trade is the whole point. A perfectly optimized system that produces incompetent operators is not optimized at all. It has simply moved its failure mode somewhere the spreadsheet cannot see it.

Put the aviation lesson and the nuclear instinct side by side and they point to one design pattern we now need in AI-augmented work: the deliberate "manual gate."

A manual gate is a point in a workflow where a human takes the controls, not because it is the fastest way to get the task done, and not only as a safety interlock, but specifically to exercise and preserve a skill that would otherwise decay. The distinguishing feature is that it is chosen. You decide, as a matter of design, which competencies your organization must keep alive in human beings because those are the ones you will need on the bad day. Then you engineer the friction required to keep them warm.

Picture how this might work on a software team that leans on AI for most of its code. The team places a manual gate around the skill it can least afford to lose: debugging. When a defect surfaces in a critical module, the assigned engineer—deliberately, often a junior one—must first reproduce the failure, trace it to root cause, and write an automated test that captures the bug, all with the AI assistant switched off. Only after the engineer commits to a diagnosis does the model come back on, to propose the fix, generate alternatives, and sweep the code base for similar bugs. The engineer then compares their diagnosis against the model's. When the two disagree, that's the design working, surfacing the disagreement before the bad day instead of during it. It's also the design teaching and training the junior engineer.

This approach reframes the junior engineer entirely. The instinct today is to let AI do the entry-level work because it is faster, cheaper and capable. But some of that work is not overhead to be eliminated. It is the training apparatus of your future senior staff, and you should protect it the way you'd protect any other piece of critical infrastructure. It may not be efficient this quarter, but dismantling it quietly mortgages your capability a decade out.

None of this is free, and pretending otherwise would insult the people who have to sign the budgets. A deliberate manual gate is, by construction, less efficient in the near term than full automation. Keeping juniors doing formative work and running the manual sequences costs something now to protect something later.

That's a hard sell in a market that judges most leaders on quarterly results. A hired executive who carries "unnecessary" humans that AI could replace will hear about it from the board long before the payoff arrives. The math only works for someone insulated from that pressure: a founder with control, a private company, an institution with a genuinely long horizon, or a regulator willing to require workers to demonstrate their skills regularly, as pilots must. This all means the organizations most likely to preserve their own expertise are the ones structurally able to spend short-term margin on long-term capability; everyone else will need a push from the outside.

So here is the argument, in one line: Deliberate inefficiency is not waste. In safety-critical engineering we have always known it as insurance, and we buy it on purpose. As AI takes over the work where expertise is forged, the smart move is not to resist the automation. It is to keep our hands on the controls by design—so that when the automation fails, as it always eventually does, there is still someone in the chair who knows how to fly.

I think that's a fantastic piece of well-reasoned engineering and I would recommend it without hesitation to anyone's boss who may currently be enraptured by AI's truly deliverable ability to eliminate all of those pesky junior engineering jobs.

We already had stunningly good AI with GPT-5.6, Fable and Mythos. And though it's going to take some time for the world to fully assess what OpenAI has just given us with GPT-6 Astra, the early take is that it currently leaves all other frontier models from OpenAI, Anthropic and Google, in the dust. Whether or not and to whatever degree that's true, even this is no more than a snapshot in time. It wasn't true a week ago; it seems to be true today. And that's my point. If we've learned anything it's that no one will ever have a long term defensible position in AI. We can count on Anthropic having a response before long, and the Chinese and other open-weight models will never be far behind.

But today, for now, Astra shows us what another generational leap in capability and compute efficiency looks like. And all this suggests that this piece's author is absolutely correct. Without the deliberate creation of an environment that's meant to nurture and mature junior developers, organizations will be left completely dependent upon automation for mission critical functions.

